

A Bug Hunter's Rhapsody: Cross Site Port Attacks - XSPA

A Bug Hunter's Rhapsody: Cross Site Port Attacks - XSPA - Author not stated, riyazwalikar.com.

- Published: date not stated
- Original:
<<https://web.archive.org/web/20170903113359/http://www.riyazwalikar.com/2012/11/cross-site-port-attacks-xspa-part-1.html>>
- Current location: <<http://www.riyazwalikar.com/2012/11/cross-site-port-attacks-xspa-part-1.html>>
- Preserved from: <http://www.riyazwalikar.com/2012/11/cross-site-port-attacks-xspa-part-1.html> (stored) on 2026-08-09
- Capture timestamp: 20130502062306
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

This is the first of a 3 part series of blog posts that explain Cross Site Port Attacks(XSPA) in greater detail. I disclosed this as a speaker at the recently concluded OWASP AppSecUSA2012, Austin and thought it was about time I blogged as well.

Read [Cross Site Port Attacks - XSPA - Part 2](#) Read [Cross Site Port Attacks - XSPA - Part 3](#)

Update: Please note that this is independent research conducted as part of my involvement with Bug Bounty programs with several companies and although related to [Alexander Polyakov's research on SSRF](#), the similarity in findings are merely a coincidence and are focused on showing how common XSPA/SSRF are in popular web applications.

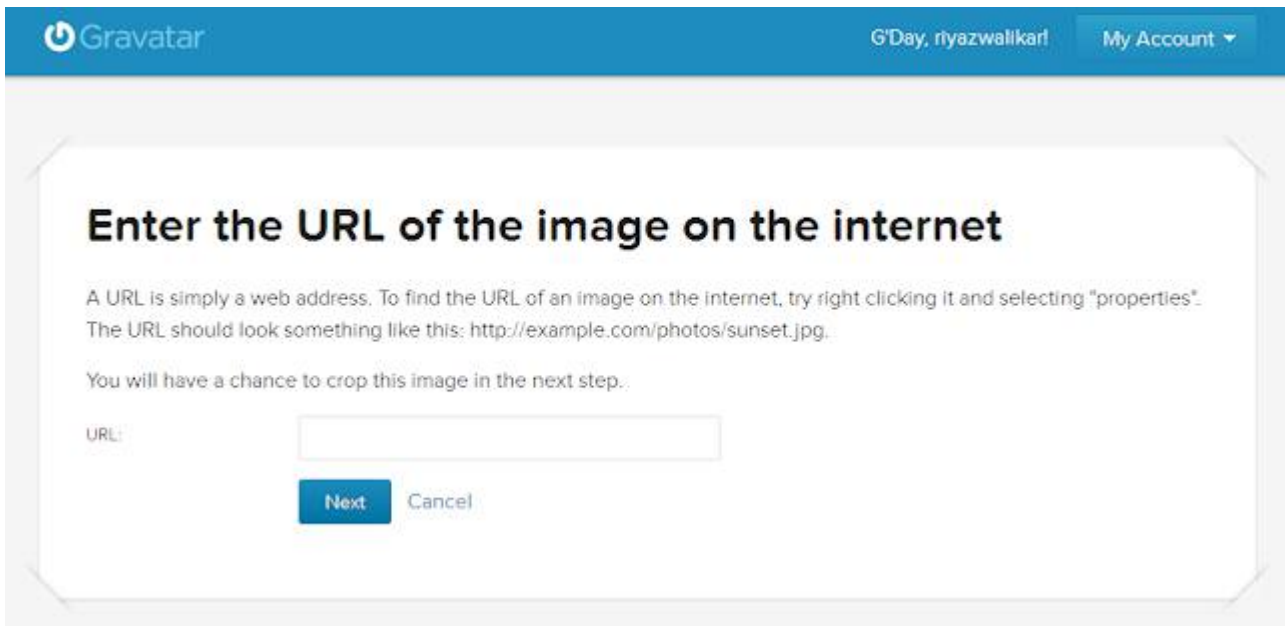
Overview

Many web applications provide functionality to pull data from other web servers for various reasons. Using user specified URLs, web applications can be made to fetch images, download XML feeds from remote servers, text based files etc. This functionality can be abused by making crafted queries using the vulnerable web application as a proxy to attack other services running on remote/local servers. Attacks arising via this abuse of functionality are named as Cross Site Port Attacks (XSPA).

What is XSPA?

An application is vulnerable to Cross Site Port Attacks if the application processes user supplied URLs and does not verify/sanitize the backend response received from remote servers before sending it back to the client. An attacker can send crafted queries to a vulnerable web application to proxy attacks to external Internet facing servers, intranet devices and the web server itself using the advertised functionality of the vulnerable web application. The responses, in certain cases, can be studied to identify service availability (port status, banners etc.) and even fetch data from remote services in unconventional ways.

The following screengrab shows gravatar.com providing this functionality:

A screenshot of the Gravatar website interface. At the top is a blue header with the Gravatar logo on the left, the text "G'Day, riyazwallikar!" in the center, and a "My Account" link with a dropdown arrow on the right. Below the header is a white rectangular box with a thin grey border. Inside this box, the heading "Enter the URL of the image on the internet" is displayed in bold. Below the heading is a paragraph of instructional text: "A URL is simply a web address. To find the URL of an image on the internet, try right clicking it and selecting 'properties'. The URL should look something like this: http://example.com/photos/sunset.jpg." Below this text is another line of text: "You will have a chance to crop this image in the next step." At the bottom of the box is a form with a label "URL:" followed by a text input field. Below the input field are two buttons: a blue "Next" button and a grey "Cancel" button.

XSPA allows attackers to abuse available functionality in most web applications to port scan intranet and external Internet facing servers, fingerprint internal (non-Internet exposed) network aware services, perform banner grabbing, identify web application frameworks, exploit vulnerable programs, run code on reachable machines, exploit web application vulnerabilities listening on internal networks, read local files using the file protocol and much more. XSPA has been discovered with Facebook, where it was possible to port scan any Internet facing server using Facebook's IP addresses. Consecutively, XSPA was also discovered in several other prominent web applications on the Internet, including Google, Apigee, StatMyWeb, Mozilla.org, Face.com, Pinterest, Yahoo, Adobe Omniture and several others. We will take a look at the vulnerabilities that were present in the above mentioned web applications that could be used to launch attacks and perform port scans on remote servers and intranet devices using predefined functionality.

Examples of Implementation

Let us look at some examples of PHP implementations of file fetching via user supplied URLs. XSPA affects web applications written in any language as long as they let users decide where the data would be fetched from. Please note the examples shown below are neither clean nor secure, however most of the parts of the code outlined below have been obtained from real world application sources.

1. PHP file_get_contents:

```
<?php if (isset($_POST['url'])) { $content = file_get_contents($_POST['url']); $filename =
'./images/'.rand().'.img1.jpg'; file_put_contents($filename, $content); echo $_POST['url'].""; $img = "
<img src=\"\".\"$filename.\"\"/>"; } echo $img; ?>
```

This implementation fetches data as requested by a user (an image in this case) using the file_get_contents PHP function and saves it to a file with a randomly generated filename on the disk. The HTML img attribute then displays the image to the user.

1. PHP fsockopen() function:

```
<?php function GetFile($host,$port,$link) { $fp = fsockopen($host, intval($port), $errno, $errstr,
30); if (!$fp) { echo "$errstr (error number $errno) \n"; } else { $out = "GET $link HTTP/1.1\r\n"; $out
.= "Host: $host\r\n"; $out .= "Connection: Close\r\n\r\n"; $out .= "\r\n"; fwrite($fp, $out);
$content="" ; while (!feof($fp)) { $content.= fgets($fp, 1024); } fclose($fp); return $content; } } ?>
```

This implementation fetches data as requested by a user (any file or HTML) using the fsockopen PHP function. This function establishes a TCP connection to a socket on the server and performs a raw data transfer.

1. PHP curl_exec() function:

```
<?php if (isset($_POST['url'])) { $link = $_POST['url']; $curlobj = curl_init(); curl_setopt($curlobj,
CURLOPT_POST, 0); curl_setopt($curlobj,CURLOPT_URL,$link); curl_setopt($curlobj,
CURLOPT_RETURNTRANSFER, 1); $result=curl_exec($curlobj); curl_close($curlobj);
$filename = './curled/'.rand().'.txt'; file_put_contents($filename, $result); echo $result; } ?>
```

This is another very common implementation that fetches data using cURL via PHP. The file/data is downloaded and stored to disk under the 'curled' folder and appended with a random number and the '.txt' file extension.

In the next part of this series, we shall see some of the attacks that can be launched using this vulnerability. XSPA allows attackers to target the server infrastructure, mostly the intranet of the web server, the web server itself and any public Internet facing server as well. Currently, I have come across the following five different attacks that can be launched using XSPA:

1. Port Scanning remote Internet facing servers, intranet devices and the local web server itself.
Banner grabbing is also possible in some cases.
1. Exploiting vulnerable programs running on the Intranet or on the local web server
2. Attacking internal/external web applications that are vulnerable to GET parameter based vulnerabilities (SQLi via URL, parameter manipulation etc.)
3. Fingerprinting intranet web applications using standard application default files & behavior
4. Reading local web server files using the file:/// protocol handler.

We will see examples of each of these scenarios in several prominent web applications on the Internet as well.